Saadhya Ayurvedalaya

Clinic Platform — Technical Architecture Reference · Generated 2026-05-06

FRAMEWORK	DATABASE	AUTH	HOSTING	DOMAIN
Next.js 14 (Pages Router)	Supabase (PostgreSQL)	Supabase Email OTP	Vercel	saadhyaayurvedalaya.com

REPO
github.com/sathwiik/sadhya-ayurvedalaya

1. TECHNOLOGY STACK

LAYER	TECHNOLOGY	NOTES
Framework	`Next.js 14` — Pages Router	SSR, ISR, API routes
Language	TypeScript	Strict mode throughout
Styling	Tailwind CSS 3	Mobile-first, no animations
Database + Auth	Supabase (PostgreSQL)	RLS enabled on all tables
Auth method	Supabase Email OTP	Passwordless magic link — doctor only
PDF generation	`@react-pdf/renderer ^3.4`	SSR-disabled via dynamic import (browser APIs)
Token generation	`nanoid v3` (21 chars)	v3 used — v5 is ESM-only, incompatible with Pages Router
Google Drive backup	`@googleapis/drive`	Drive-only package — not full googleapis (size)
Markdown	`react-markdown v8`	v8 used — v9 is ESM-only
Scheduling	Vercel Cron	Backup only — monthly, 1st of month 01:00 UTC

ESM note: nanoid v5 and react-markdown v9 are ESM-only and incompatible with Next.js Pages Router (CommonJS). Pinned to v3 and v8 respectively.

2. DATABASE SCHEMA

Run in Supabase SQL editor. All tables have RLS enabled. Doctor (authenticated) has full access. Token-based patient access uses service role key in API routes — bypasses RLS intentionally.

TABLE	KEY COLUMNS	NOTES
patients	id, name, phone (UNIQUE), dob, address, aadhaar_last4	Aadhaar last 4 digits only — never full number
appointments	id, patient_id, appt_date, time_slot, mode, status, chief_complaint, diagnosis, clinical_notes, follow_up_date, token (UNIQUE), token_expires_at, token_active, link_sent, reminder_sent, consent_given, consent_at	Hub table. token_active and link_sent added post-spec.
prescriptions	id, appointment_id, drug_name, dosage, frequency, days, notes	Many per appointment. All TEXT fields.
billing	id, appointment_id (UNIQUE), patient_id, fee, items (JSONB), paid, payment_mode, paid_at	Auto-created (empty) when appointment is created
medicine_stock	id, drug_name (UNIQUE), quantity, unit, low_stock_threshold, price	Used for prescription drug autocomplete
content_posts	id, title, body, published, created_at, updated_at	Anon read if published=true
settings	id=1, clinic_name, doctor_name, address, phone, email, consent_text	Always one row. id=1 enforced.

Migrations to run after base schema

> **CHANGE_001:** `ALTER TABLE appointments ADD COLUMN link_sent BOOLEAN DEFAULT false;`
> **CHANGE_002:** `ALTER TABLE appointments ADD COLUMN token_active BOOLEAN DEFAULT true;`

3. FILE STRUCTURE

PAGES — PUBLIC

- `/` — Homepage (SSR)
- `/blog` — Posts list (SSR)
- `/blog/[id]` — Post, react-markdown (ISR 300s)
- `/appt/[token]` — Patient token page (SSR)
- `/login` — Doctor email OTP

PAGES — ADMIN (AUTH-GUARDED)

- `/admin` — Dashboard
- `/admin/patients` — List + detail
- `/admin/appointments` — List + new + edit
- `/admin/messages` — Unsent links + reminders
- `/admin/prescriptions/[id]` — Drugs + PDF
- `/admin/stock` — Medicine inventory
- `/admin/billing` — Billing + receipt PDF
- `/admin/posts` — Blog CMS
- `/admin/settings` — Clinic config

API ROUTES

- `POST /api/appointments/create`
- `GET /api/token/[token]`
- `POST /api/consent`
- `POST /api/messages/mark-link-sent`
- `POST /api/messages/mark-reminder-sent`
- `GET /api/backup/run` (cron)

COMPONENTS

- `AdminLayout.tsx` — sidebar + auth guard
- `PublicLayout.tsx` — header + footer
- `ConsentModal.tsx` — full-screen overlay
- `PrescriptionPDF.tsx` — A5 react-pdf
- `ReceiptPDF.tsx` — A5 billing receipt

4. KEY DATA FLOWS

Create Appointment

1. Doctor fills 2-step form (phone lookup → appointment details)
2. POST /api/appointments/create (session auth)
3. Service role: INSERT patients ON CONFLICT (phone) DO UPDATE → patient_id
4. Generate nanoid(21) token, token_expires_at = now() + 30 days
5. INSERT appointments (token_active defaults true, link_sent defaults false)
6. INSERT billing (fee=0, items=[], auto-created)
7. Return { appointment_id, token_url } — no SMS sent
8. Doctor copies link from success screen → goes to Messages page to send manually

Patient Token Page

1. Patient opens /appt/[token] (link received via WhatsApp/SMS from doctor manually)
2. getServerSideProps → GET /api/token/[token] using service role key
3. API checks: token exists → not expired → token_active = true
   - 404: invalid token → "Invalid link" page
   - 410: token_expires_at passed → "Link expired" page
   - 403 + disabled:true → "Details unavailable" page (neutral, no reason given)
4. If consent_given = false → ConsentModal overlay (cannot dismiss by clicking outside)
   - "Yes" → POST /api/consent → consent_given=true, consent_at=now() → full view
   - "No" → minimal view: date, time, clinic name, doctor name only
5. If consent_given = true (returning visitor) → skip modal, full view directly
6. Safe fields returned: name, date, time, mode, doctor, complaint, diagnosis*, prescriptions*, follow_up*
   * only if status = completed. Never returns: phone, Aadhaar, billing, clinical_notes.

Messages Workflow (CHANGE_001 — replaces automated SMS)

Doctor opens /admin/messages → two tabs:
Unsent links: appointments WHERE link_sent=false AND token IS NOT NULL. Doctor copies pre-written message → pastes into WhatsApp → taps "Mark as sent" → link_sent=true, card removed.

Reminders: appointments WHERE appt_date=tomorrow AND status=scheduled AND reminder_sent=false. Same copy+mark flow → reminder_sent=true.

Token Access Toggle (CHANGE_002)

On /admin/appointments/[id]: toggle switch controls token_active column. Saves immediately on tap.
token_active=false → API returns 403 { disabled: true } → patient sees "Details unavailable" (not "expired").
Tokens are never deleted from the database. Doctor re-enables at any time.

Monthly Backup (Vercel Cron)

Schedule: 0 1 1 * * (1st of month, 01:00 UTC)
Auth: Authorization: Bearer CRON_SECRET header
Fetches all 6 tables + clinic name from settings in parallel
Uploads saadhya_backup_YYYY_MM.json to Google Drive via service account
Auth uses @googleapis/drive bundled GoogleAuth (not separate google-auth-library)

5. SECURITY MODEL

AUTHENTICATION

- Doctor: Supabase email OTP (magic link) — no password
- middleware.ts protects all /admin/* — redirects unauthenticated to /login
- Doctor account created once manually in Supabase dashboard
- Cron routes: Authorization: Bearer CRON_SECRET

SUPABASE CLIENTS

- `lib/supabase.ts` — anon key, browser-safe, RLS enforced
- `lib/supabaseAdmin.ts` — service role, API routes ONLY
- Service role key never imported in any page or component

DATA PRIVACY

- Aadhaar: last 4 digits only — full 12-digit number never stored
- Token page: appointment_id never exposed to client
- Token page never returns: phone, Aadhaar, billing, clinical_notes
- Consent tracked: consent_given + consent_at per appointment
- Doctor can disable any token link (token_active toggle)

KNOWN LIMITATIONS (MVP)

- Token link = single credential, no second factor
- Consent set by first opener of link (family member risk)
- No rate limiting on /api/token/[token]
- as any casts on Supabase joins (no generated types)
- See docs/FUTURE_ADDITIONS.md for remediation plan

6. DESIGN SYSTEM

ROLE	TAILWIND	USAGE
Primary	`green-700` #15803d	Buttons, links, active sidebar, headings
Accent	`amber-600` #d97706	Low stock, pending counts, warnings
Background	`gray-50`	All page backgrounds
Cards	`white` + `gray-200` border	rounded-lg throughout
Danger	`red-600`	Delete actions, warning boxes
Status: Scheduled	blue	rounded-full px-2 py-0.5 text-xs font-medium
Status: Completed	green	Same pill shape
Status: Cancelled	gray	Same pill shape
Status: No-show	amber	Same pill shape

Font: Inter (Google Fonts via _document.tsx). All admin tables wrapped in overflow-x-auto. No animations.

7. ENVIRONMENT VARIABLES

VARIABLE	USED IN	NOTES
`NEXT_PUBLIC_SUPABASE_URL`	Browser + server	Supabase project URL
`NEXT_PUBLIC_SUPABASE_ANON_KEY`	Browser + server	Safe for client — RLS enforced
`SUPABASE_SERVICE_ROLE_KEY`	API routes only	Never expose to client
`GOOGLE_DRIVE_FOLDER_ID`	Backup cron	Target Drive folder
`GOOGLE_SERVICE_ACCOUNT_JSON`	Backup cron	Full JSON string of service account credentials
`NEXT_PUBLIC_SITE_URL`	Browser + server	https://saadhyaayurvedalaya.com
`CRON_SECRET`	Cron API routes	Bearer token — generate with openssl rand -hex 32

> MSG91 variables removed (CHANGE_001). No SMS integration in MVP — doctor sends messages manually via Messages page.

8. DEPLOYMENT CHECKLIST

STEP	ACTION
1	Run base schema SQL in Supabase SQL editor
2	Run CHANGE_001 migration: ADD COLUMN link_sent BOOLEAN DEFAULT false
3	Run CHANGE_002 migration: ADD COLUMN token_active BOOLEAN DEFAULT true
4	Create doctor account in Supabase Auth dashboard (email only)
5	Fill in all .env.local values, add same vars to Vercel project settings
6	Create Google service account, share target Drive folder with it, paste JSON into env var
7	Connect repo to Vercel, deploy
8	Visit /admin/settings — set clinic name, doctor name, address, phone, consent text
9	Verify backup cron fires (Vercel Pro required, or use cron-job.org — see docs/FUTURE_ADDITIONS.md)